

INTRODUCTION AU TEST D'INTRUSION

Grille de risque

Projet final · Conduire une mission sur dossier



Usage

Cette grille sert à classer, noter et prioriser les constats du dossier. Les exemples ci-dessous utilisent des valeurs inventées qui ne correspondent à aucune réponse du laboratoire.

Statuts de preuve

- ◆ **constat** : au moins deux preuves convergentes, ou une preuve directement démonstrative et relue.
- ◆ **hypothese** : signal plausible mais preuve unique, partielle ou non corroborée.
- ◆ **faux_positif** : signal infirmé par un export plus fiable du dossier.

OWASP Top 10 2025

CODE	INTITULÉ	QUAND L'UTILISER DANS CE PARCOURS
a01	Broken Access Control	Accès à un objet, une fonction ou une cible serveur sans droit, y compris une SSRF pilotée par le client.
a02	Security Misconfiguration	En-tête absent, service inattendu, protocole faible, console exposée.
a03	Software Supply Chain Failures	Composant tiers vulnérable ou non mis à jour.
a04	Cryptographic Failures	Secret, protocole ou protection cryptographique insuffisante.
a05	Injection	Donnée interprétée comme requête, code ou contenu actif.
a06	Insecure Design	Règle de sécurité absente dès la conception.
a07	Authentication Failures	Secret de session, mot de passe ou vérification d'identité insuffisants.
a08	Software or Data Integrity Failures	Donnée ou logiciel acceptés sans contrôle d'intégrité.
a09	Security Logging and Alerting Failures	Trace utile manquante ou alerte absente.
a10	Mishandling of Exceptional Conditions	Erreur ou condition exceptionnelle mal traitée.

Les intitulés sont repris tels quels depuis OWASP Top 10:2025. Dans ce parcours, une SSRF pilotée par l'utilisateur reste rattachée à `a01` quand elle contourne un contrôle d'accès serveur.



Formule CVSS 3.1

- ◆ AV : N 0,85 ; A 0,62 ; L 0,55 ; P 0,20
- ◆ AC : L 0,77 ; H 0,44
- ◆ PR si S:U : N 0,85 ; L 0,62 ; H 0,27
- ◆ PR si S:C : N 0,85 ; L 0,68 ; H 0,50
- ◆ UI : N 0,85 ; R 0,62
- ◆ C, I, A : H 0,56 ; L 0,22 ; N 0
- ◆ $ISS = 1 - (1 - C) \times (1 - I) \times (1 - A)$
- ◆ Impact si S:U = $6,42 \times ISS$
- ◆ Impact si S:C = $7,52 \times (ISS - 0,029) - 3,25 \times (ISS - 0,02)^{15}$
- ◆ Exploitabilité = $8,22 \times AV \times AC \times PR \times UI$
- ◆ Si l'impact est nul, la note vaut 0,0
- ◆ Sinon la note est l'arrondi supérieur au dixième de la formule officielle FIRST 3.1



Qualification CVSS 3.1

NOTE	QUALIFICATION
0,0	None
0,1 à 3,9	Low
4,0 à 6,9	Medium
7,0 à 8,9	High
9,0 à 10,0	Critical



Arrondi Roundup

- ◆ multiplie d'abord l'entrée par 100000 ;
- ◆ arrondis au plus proche entier avant tout autre calcul ;
- ◆ si les quatre derniers chiffres valent 0000, garde la valeur telle quelle ;
- ◆ sinon passe au dixième supérieur en restant en arithmétique entière jusqu'à la dernière division.



EPSS et KEV

- ◆ EPSS estime la probabilité d'exploitation dans la nature sur les 30 prochains jours, sur une échelle de 0 à 1;
- ◆ KEV recense les vulnérabilités déjà exploitées dans la nature et sert de signal fort de priorisation;
- ◆ ni EPSS ni KEV ne remplacent la preuve locale, le périmètre ou l'impact métier.



Facteurs de priorité

DIMENSION	VALEUR	FACTEUR
surface	internet	1,6
surface	vpn	1,3
surface	interne	1,0
criticite_metier	critique	1,7
criticite_metier	elevée	1,4
criticite_metier	moyenne	1,1
preuve	suffisante	1,3
preuve	partielle	1,1
preuve	insuffisante	0,8
kev	oui	1,3
kev	non	1,0
epss_30j	inférieur à 0,30	1,0
epss_30j	de 0,30 à 0,69	1,2
epss_30j	supérieur ou égal à 0,70	1,4

Priorité numérique = note CVSS × facteur surface × facteur criticité métier × facteur preuve × facteur KEV × facteur EPSS.

La priorité est arrondie au dixième le plus proche. En cas d'égalité, on départage par la note CVSS la plus haute, puis par l'identifiant le plus petit.



Exemple inventé

Vecteur d'exemple : `CVSS:3.1/AV:N/AC:H/PR:L/UI:R/S:U/C:L/I:L/A:N`. Avec la formule ci-dessus, ISS = 0,3916, impact = 2,514, exploitabilité = 1,1818, donc une note CVSS 3.1 de 3,7.

Supposons que ce constat ait une surface `vpn`, une criticité `elevée`, une preuve `partielle`, `kev = non` et `epss_30j = 0,34`.

La priorité devient $3,7 \times 1,3 \times 1,4 \times 1,1 \times 1,0 \times 1,2 = 8,9$ après arrondi au dixième.



Bon usage dans le rapport

- ◆ le résumé exécutif reste factuel et ne transforme pas une hypothèse en compromission ;
- ◆ une recommandation décrit une action vérifiable ;
- ◆ un ordre d'actions suit la priorité numérique, puis la faisabilité immédiate ;
- ◆ un écart au cadrage ou un nettoyage restant à traiter doit être nommé explicitement.
- ◆ une hypothèse ne devient pas un constat sans deuxième preuve indépendante ou preuve directement démonstrative.



Pingo veille sur ta progression

Retourne au laboratoire pour valider tes réponses. Bloqué ? Ouvre d'abord l'indice de la tâche, la correction vient ensuite.